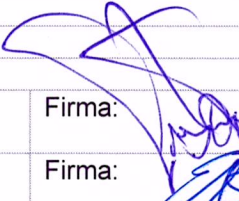
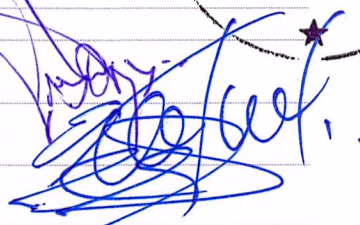
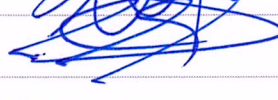


**PROCEDIMIENTO
DE ANALISIS DE SEGURIDAD PARA SISTEMAS Y SITIOS WEB**

Sistema de Gestión de Seguridad de la Información – Nivel Central

Código	PROS-NC-009	
Versión oficial:	V 1.0	
Fecha de la versión:	21.02.2024	
Elaborado por:	Pablo Fabres /Jose Villa C.	Firma: 
Revisado por	Jose Villa C.	Firma: 
Revisado por	Carlos Maldonado P.	Firma: 
Aprobado por:	Jorge Herrera R./ Rodrigo Zamorano	Firma: 



Contenido

1	PROPÓSITO	3
2	ALCANCE	3
3	TERMINOLOGÍA.....	3
4	DOCUMENTOS APLICABLES.....	4
5	ROLES Y RESPONSABILIDADES.....	4
6	PROCEDIMIENTO.....	5
6.1	REQUISITOS PREVIOS.....	5
6.2	ESQUEMA DE TRABAJO	5
6.3	PLANIFICACIÓN.....	6
6.4	REALIZACIÓN DE SCANNER DE SEGURIDAD	6
6.5	CONTENIDO DEL INFORME ANALISIS DE VULNERABILIDADES.....	6
6.6	REMEDIACIÓN	7
7	REGISTROS.....	7
8	DIFUSION	7
9	REVISION	7
10	CONTROL DE VERSIONES.....	7
11	ANEXO N°1: FORMULARIO DE SOLICITUD DE SCANNER DE SEGURIDAD	8
12	ANEXO N°2	10

1 PROPÓSITO

Robustecer la seguridad y mejorar los mecanismos de protección de los productos de software desarrollados para Minsal, con el objetivo de mitigar o disminuir las falencias detectadas y con ello minimizar los riesgos tecnológicos que pudiera presentar el paso producción y a ser expuestos a Internet.

2 ALCANCE

Este procedimiento aplica para cualquier producto de software que sea expuesto a internet, desarrollos propios o soluciones comerciales para el Ministerio de Salud, la Subsecretaría de Salud Pública, la Subsecretaría de Redes Asistenciales.

Esta política abarca los siguientes controles definidos en la norma NCh-ISO 27002:2013, denominada “Tecnologías de la información-Técnicas de seguridad-Códigos de prácticas para los controles de seguridad de la información” y, en específico:

- A.09.04.05 Control de acceso al código fuente de los programas
- A.14.01.01 Análisis y especificación de los requisitos de seguridad de la información
- A.14.02.01 Política de desarrollo seguro
- A.14.02.02 Procedimientos de control de cambios del sistema
- A.14.02.06 Entorno de desarrollo seguro
- A.14.02.08 Prueba de seguridad del sistema
- A.14.02.09 Prueba de aprobación del sistema

3 TERMINOLOGÍA

- **Amenaza:** Un evento o acción que tiene el potencial de comprometer la seguridad del sistema, como un ataque malicioso, un fallo del sistema o desastres naturales.
- **Análisis de Riesgos:** El proceso de evaluar los riesgos potenciales en un sistema, identificando vulnerabilidades y amenazas, y determinando la probabilidad e impacto de su explotación.
- **Análisis de Vulnerabilidades:** Identificación y evaluación de debilidades en sistemas y redes que podrían ser explotadas por amenazas. Tiene por objetivo el identificar y corregir vulnerabilidades antes de que sean aprovechadas.
 - Análisis de Código Dinámico: Evaluación del comportamiento de una aplicación mientras se está ejecutando. Se realiza mediante pruebas y monitoreo en tiempo real durante la ejecución de un programa, identificando posibles vulnerabilidades y problemas de seguridad que podrían surgir en situaciones de uso reales.
 - Análisis de Código Estático: Evaluación que se realiza sin ejecutar el programa. Consiste en examinar el código fuente de una aplicación para identificar posibles vulnerabilidades, errores de programación y prácticas inseguras.
- **Controles de Seguridad:** Medidas implementadas para proteger activos de información, como firewalls, cifrado, autenticación, y políticas de acceso.
- **Scanner de seguridad:** También conocido como scanner de vulnerabilidades, es un proceso automatizado mediante el cual se examinan sistemas informáticos, redes, aplicaciones o dispositivos en busca de posibles debilidades y vulnerabilidades que podrían ser explotadas por amenazas maliciosas. Se lleva a cabo utilizando herramientas especializadas y/o pruebas manuales que buscan activamente vulnerabilidades conocidas, configuraciones incorrectas o debilidades en la seguridad.
- **Incidente de Seguridad:** Un evento que indica una posible violación de la seguridad de la información, como un acceso no autorizado, pérdida de datos, o interrupción del servicio.

- **Informe de Análisis de Vulnerabilidades:** Presenta los resultados del análisis de vulnerabilidades llevado a cabo en un sistema, red, aplicación o entorno específico. El objetivo principal de este análisis es identificar posibles debilidades y riesgos de seguridad que puedan comprometer la integridad, confidencialidad o disponibilidad de la información. La implementación de las recomendaciones propuestas en este informe contribuirá significativamente a reducir los riesgos y fortalecer la postura de seguridad de la organización.
- **Pen-Testing:** Una evaluación activa de la seguridad de un sistema mediante la simulación de ataques para identificar vulnerabilidades y evaluar la efectividad de las medidas de seguridad existentes.
- **Política de Seguridad:** Un conjunto de reglas y directrices que definen cómo deben manejarse y protegerse los activos de información en un sistema o sitio web.
- **Riesgo de Seguridad:** La probabilidad de que una amenaza explote una vulnerabilidad y cause un impacto no deseado en el sistema.
- **Vulnerabilidad:** Una debilidad en el sistema o en un componente que podría ser explotada para comprometer la seguridad del sistema.

4 DOCUMENTOS APLICABLES

Dentro de la normativa, marcos de trabajo y documentos relacionados, y que son aplicables al presente procedimiento, se asocian los siguientes:

- Nch-ISO 27001.Of2013, Sobre los requisitos de la seguridad de la información.
- Decreto 1 del año 2015, del Ministerio de la Secretaría General de la Presidencia, que aprueba la norma técnica sobre sistemas y sistemas web de los órganos de la administración del estado.
- Decreto 83 del año 2004, del Ministerio de la Secretaría General de la Presidencia, que aprueba la norma técnica para los órganos de la administración del estado sobre la seguridad y confidencialidad de los documentos electrónicos.
- Decreto 7 del año 2023, del Ministerio de la Secretaría General de la Presidencia, que establece la norma técnica de seguridad de la información y ciberseguridad.

5 ROLES Y RESPONSABILIDADES

- Encargado de Seguridad de la Información: Debe velar por la aplicación del presente procedimiento y brindar asesoramiento en la identificación de las amenazas que pueden afectar a los activos de información y las vulnerabilidades que propician las mismas e informar al Comité de Seguridad de la Información sobre bajas o revocaciones de sistemas web que se tramiten.
- Los dueños de los activos de información: Propietarios de los activos tendrán que dar aplicación al presente procedimiento y justificar formalmente cuando se requiera levantar una carta de riesgos.
- Usuarios (Jefe Proyecto TIC - Gestor TI o referentes de negocio):
 - Responsable de solicitar el Análisis de Seguridad (vulnerabilidades) para los productos de software que son expuestos a internet.
 - Responsable de la entrega de información requerida por la Unidad Seguridad de la Información y Ciberseguridad, además de la realización de los respaldos según corresponda.
 - Planificar los plazos de puesta en producción en consideración de los tiempos indicados en este procedimiento para el análisis y emisión del informe de análisis de vulnerabilidades.
 - Es responsable de gestionar la corrección de las vulnerabilidades encontradas por la Unidad de Ciber y Seguridad de la Información a través del Plan de Remediación de vulnerabilidades encontradas.

- Responsable de la Planificación del Proyecto en los tiempos que signifiquen dar solución a las vulnerabilidades y las etapas asociadas a la Producción/Explotación.
- Unidad de Seguridad de la Información y Ciberseguridad del Minsal.
 - Agendar, programar y priorizar, los requerimientos para scanner de seguridad de sistemas o sitios web, que realicen los usuarios.
 - Elaborar los Informe de Análisis de Vulnerabilidades.
 - Informar de vulnerabilidades encontradas en cada análisis que se realice por aplicativo.
 - Realizar las recomendaciones de mejora a las vulnerabilidades encontrada en cada análisis.

6 PROCEDIMIENTO

6.1 REQUISITOS PREVIOS

El usuario deberá proporcionar a la Unidad de Seguridad de la Información y Ciberseguridad, a través del “Formulario de solicitud de scanner de seguridad”, la siguiente información:

- Dirección de la IP donde se aloja el aplicativo.
- URL
- Indicar ambiente en que se encuentra el aplicativo para realizar el análisis.
- Informar si contiene información sensible
- Confirmar la existencia de un Respaldo al aplicativo y/o BBDD según corresponda.
- Programación de fechas tentativas para la realización del análisis.
- Proporcionar credenciales de prueba de la aplicación o servidor.

6.2 ESQUEMA DE TRABAJO

- El Usuario, deberá enviar un correo a mds@minsal.cl, con copia a la casilla seguridadtic@minsal.cl, adjuntando el “Formulario de solicitud de scanner de seguridad” Anexo N°1, con la completitud de la información requerida.
- La Unidad de Seguridad de la Información y Ciberseguridad agendará, según los datos enviados para su posterior análisis del aplicativo o del servicio solicitado. Si la información proporcionada en el Formulario de solicitud de scanner de seguridad no está completa o es incorrecta, entonces se responderá al usuario, para que se complemente y se procederá a cerrar el ticket del requerimiento. En caso de que el Formulario viene completo se informará al usuario que se dará inicio de Análisis de Seguridad.
- Una vez terminado el proceso de análisis, la Unidad de Seguridad de la Información y Ciberseguridad elaborará el “Informe de Análisis de Vulnerabilidades” Anexo 2, que incluye vulnerabilidades que deberá subsanar el Usuario y recomendaciones asociadas. En el caso de existir vulnerabilidades, el Usuario debiera presentar posteriormente un Plan de Remediación, fecha de próximo Análisis de Vulnerabilidad y reiniciar este procedimiento.
- En el caso de no existir vulnerabilidades, se informará que no existen inconvenientes para su paso a producción.
- La Unidad de Seguridad de la Información y Ciberseguridad, enviará el Informe de Análisis de Vulnerabilidades al usuario, y procederá al cierre del requerimiento.

6.3 PLANIFICACIÓN

El usuario debe tener en cuenta un plazo máximo de 48 horas hábiles a partir de la recepción del requerimiento por parte de la Unidad de Seguridad de la Información y Ciberseguridad. Este periodo se destina para llevar a cabo el análisis necesario y elaborar el informe correspondiente, que incluirá las vulnerabilidades identificadas junto con las recomendaciones para su corrección. Por lo tanto, se recomienda planificar el requerimiento en las fases iniciales del proyecto.

6.4 REALIZACIÓN DE SCANNER DE SEGURIDAD

- Cada revisión contará con las siguientes fases:
- Recolección de información.
 - Realización de tests con herramientas automáticas y pruebas manuales.
 - Revisión de los resultados de las herramientas automáticas y comprobación de los resultados.
 - Elaboración de informe, incluyendo las acciones correctoras.

Durante la realización del scanner de seguridad y, especialmente, durante la fase de realización de tests con herramientas automáticas, podría ocurrir que las pruebas afectaran a la disponibilidad de los servicios publicados. Por este motivo, se acordarán el horario y calendario en el que las pruebas están autorizadas por el usuario.

El Análisis de Seguridad se basa en una metodología estándar y abierta para el desarrollo de pruebas de seguridad de aplicaciones web (Open Web Application Security Project (OWASP), que permite rescatar las buenas prácticas y top 10 de las recomendaciones a los análisis de aplicativos, que incluye:

- Buscar las causas de la inseguridad en el software.
- Recomendar soluciones a las amenazas descubiertas.

Una vez realizado el análisis, se emitirá el informe con los resultados y las recomendaciones para corregir las vulnerabilidades detectadas.

6.5 CONTENIDO DEL INFORME ANALISIS DE VULNERABILIDADES

La Unidad de Seguridad de la Información y Ciberseguridad elaborará un “Informe de Análisis de Vulnerabilidades” detallando los resultados de las vulnerabilidades y acciones recomendadas para resolver los fallos de seguridad encontrados y proteger eficazmente los sistemas de información y aplicaciones.

El informe contendrá, al menos, la siguiente información:

- Descripción: Clara identificación de los activos analizados (URL, nombres de los equipos e IPs analizadas).
- Alcance: Para cada uno de los activos analizados indicará qué aspectos se han revisado (protocolos, puertos, vulnerabilidades conocidas, etc.).
- Resultados: Donde se recogerán las vulnerabilidades encontradas, su tipología, su criticidad y los sistemas afectados por ellas. Agrupadas de acuerdo a lo siguientes tipos:
 - Número de vulnerabilidades identificadas.
 - Nivel de Severidad
 - Vulnerabilidades de los Sistemas Operativos.
 - Vulnerabilidades en Aplicaciones Propietarias y Aplicaciones Comerciales.
 - Vulnerabilidades en la autenticación y/o Control de Acceso.
 - Riesgo en el acceso a la Red (LAN).

- Explotación de vulnerabilidades.
- Acciones Recomendadas: Método para subsanar las vulnerabilidades encontradas. Qué acciones hay que tomar para la subsanación de las vulnerabilidades encontradas.

6.6 REMEDIACIÓN

El usuario debe presentar un Plan de Remediación que aborde las deficiencias identificadas en el Informe de Vulnerabilidades. Una vez implementadas las correcciones y subsanadas las vulnerabilidades, se debe solicitar un nuevo análisis, siguiendo el procedimiento establecido. En caso de que esta revisión no revele nuevas vulnerabilidades, la Unidad de Seguridad de la Información y Ciberseguridad aprobará el análisis mediante el "Informe de Análisis de Vulnerabilidades" y notificará al usuario por correo electrónico. Posteriormente, se procederá al cierre del requerimiento. Esta formalidad será un requisito esencial para avanzar a la fase de Producción del Aplicativo.

El usuario deberá considerar y ajustar en la Planificación del Proyecto los tiempos necesarios para abordar las vulnerabilidades y las etapas subsiguientes relacionadas con la Producción/Explotación

7 REGISTROS

- Formulario de solicitud de scanner de seguridad
- Informe de Análisis de Vulnerabilidades

8 DIFUSION

La comunicación del presente documento se efectuará de manera que el contenido de la documentación sea accesible y comprensible para todos los usuarios, a lo menos se deberá hacer difusión mediante los siguientes canales:

- Publicación en sistemaweb de Minsal http://www.minsal.cl/seguridad_de_la_informacion/
- Publicación en la intranet de Minsal <http://isalud.minsal.cl/>

9 REVISION

La revisión del contenido de este documento se efectuará a lo menos cada dos años por el Comité de Seguridad de la Información, o atendiendo necesidades de cambios para garantizar versionamientos respectivos recomendables.

10 CONTROL DE VERSIONES

Versión	Fecha	Creado por	Pág. o Sección modificada	Descripción de la modificación
1	20.02.2024	Pablo Fabres /Jose Villa C.	Todo el documento	Actualización del documento

11 ANEXO N°1: FORMULARIO DE SOLICITUD DE SCANNER DE SEGURIDAD

*Todos los campos son obligatorios

Fecha de solicitud	
--------------------	--

DATOS DEL SOLICITANTE	
Nombre	
Cargo	
Rut	
Establecimiento	
Área / Departamento / Unidad	
Teléfono	
email	

DATOS DEL RESPONSABLE DE LA AUTORIZACIÓN	
Nombre	
Cargo	
Rut	
Establecimiento	
Área / Departamento / Unidad	
Teléfono	
email	

IDENTIFICACIÓN DEL ACTIVO		
Nombre del activo		
Descripción de objetivos y alcance tiene el activo		
Maneja datos sensibles ¹	SI ☐	NO ☐
¿El activo se encuentra expuesto a internet?	SI ☐	NO ☐
¿Será expuesto a internet?	SI ☐	NO ☐
URL(s) (enlace directo)		
Dirección(es) IP (aplicativo y servidor)		
Lenguaje(s)		
Credenciales del aplicativo (de prueba o lectura)	Usuario:	Clave:
Credenciales del servidor (de prueba o lectura)	Usuario:	Clave:

MEDIDAS DE RESGUARDO DEL ACTIVO			
¿El activo se encuentra respaldado?	SI ☐	NO ☐	
¿La base de datos se encuentra respaldada?	SI ☐	NO ☐	
Ambiente donde se encuentra(n) el(los) activos	DESARROLLO ☐	QA ☐	PRODUCCIÓN ☐
Fecha(s) en que se solicita realizar el análisis			
Ventana horaria			

¹ Según la ley 19.628 se entiende por datos sensibles “aquellos datos personales que se refieren a las características físicas o morales de las personas o a hechos o circunstancias de su vida privada o intimidad, tales como los hábitos personales, el origen racial, las ideologías y opiniones políticas, las creencias o convicciones religiosas, los estados de salud físicos o psíquicos y la vida sexual”.

Toda versión impresa de este documento se considera como Copia No Controlada.

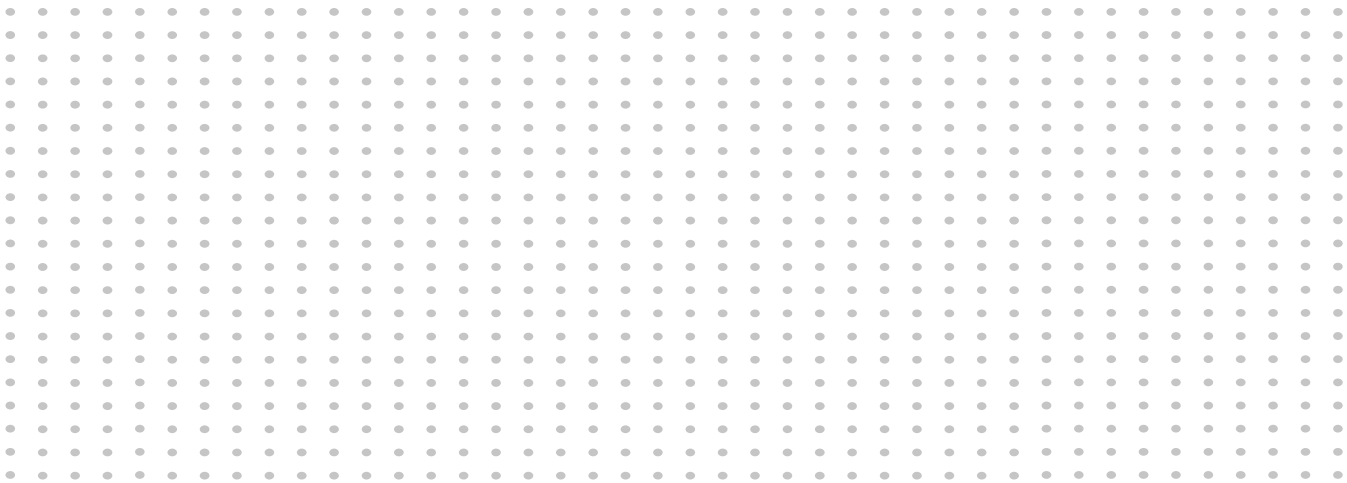
APROBACIÓN

Nombre y firma del solicitante

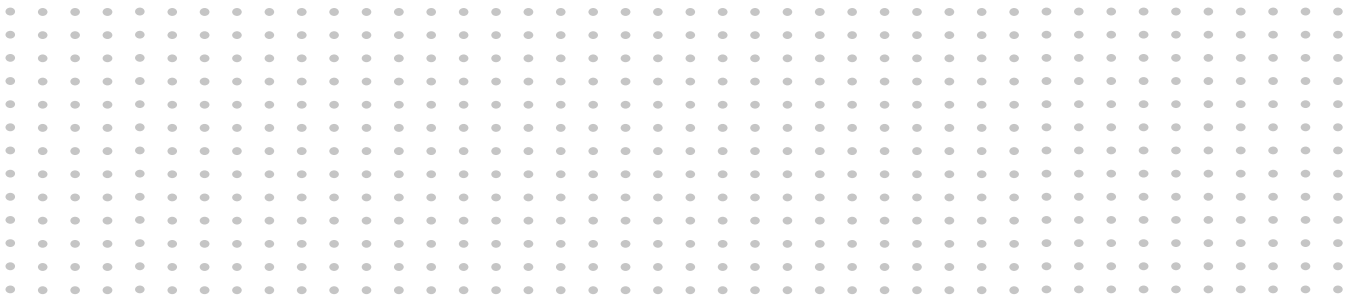
Nombre y firma del responsable de la autorización

- Notas:
- 1. Los scanners a sitios web, servidores o endpoint eventualmente, pueden conllevar consecuencias negativas en estos servicios, tales como lentitud, reinicio, modificaciones en la base de datos, entre otros.
 - 2. En caso de que se solicite el scan sin los respaldos respectivos, es responsabilidad del solicitante la integridad de los activos.
 - 3. El responsable de la solicitud, lo es también para efectos de coordinación y la toma de los resguardos necesarios para llevar a cabo con éxito la solicitud.

12 ANEXO N°2



INFORME DE ANÁLISIS DE VULNERABILIDADES
[Nombre activo]
[versión]
Departamento Tecnologías de la Información y Comunicaciones
Unidad de Seguridad de la Información y Ciberseguridad
[Fecha]



DESCRIPCIÓN

Se realizan los chequeos tanto de la plataforma como solución del sitio [xxxxxxxxxxxxxxxxxxxxxxxxxxxx] en busca de vulnerabilidades.

ALCANCES

- La revisión tanto de la plataforma como de la solución será a través de sistemas de detección de vulnerabilidades. En ningún caso se tratará de ingresar por consola.
- La información entregada es parcial, no se cuenta con el código fuente para lograr subsanar en su totalidad el aplicativo.
- Revisión de vulnerabilidades a nivel servidor.
- Revisión de vulnerabilidades a nivel aplicativo.

RESULTADOS

SEVERIDAD	MEDIO/ALTO/CRITICO
ITEM AFECTADO	
DESCRIPCION	SLQ- INJECTIONS
DETALLE	Parámetros sin cifrado en donde puedo ejecutar códigos maliciosos para sacar información privilegiada
ACCIONES RECOMENDADAS	

CONCLUSIONES

Sugerimos la mitigación de las vulnerabilidades agregando Información con apoyos de URL´s válidas.

APROBACIÓN

Analista Unidad de Ciber y Seguridad de la Información	Encargado Unidad de Ciber y Seguridad de la Información
---	--